

Differential Cryptanalysis of 4-Round DES

Reference Solution and Query-Budget Justification

1 The cipher

The oracle implements DES reduced to four rounds with the standard FIPS-46 S-boxes and the standard E , P , PC-1, PC-2 tables and shift schedule $[1, 1, 2, 2]$. The initial and final permutations are omitted; since they are fixed, key-independent bit permutations they have no effect on a differential attack. Writing each round as

$$L_i = R_{i-1}, \quad R_i = L_{i-1} \oplus F(R_{i-1}, K_i),$$

the 64-bit output (with the standard pre-output swap) is

$$C = (R_4 \parallel L_4).$$

A prime denotes an XOR difference between the two members of a chosen-plaintext pair, e.g. $R'_2 = R_2 \oplus R_2^*$.

Oracle access. The attack is mounted purely through the deployed encryption oracle's HTTP JSON API (POST `/api/encrypt` with body `{"plaintext": "<16 hex>"}`, returning `{"ciphertext": "<16 hex>"}`); the secret key is never read by the attack code. All numbers reported below are from a live run against the remote oracle at <http://des.rathanappana.com>.

2 Reduction to a last-round attack

Two halves are read *directly* from the ciphertext:

$$R_4 = C_{[0:32]}, \quad R_3 = L_4 = C_{[32:64]}.$$

Because $R_4 = R_2 \oplus F(R_3, K_4)$, the output difference of the fourth-round F function satisfies

$$F(R_3, K_4) \oplus F(R_3^*, K_4) = R'_4 \oplus R'_2. \tag{1}$$

The input to that F function, $R_3 = L_4$, is known for both texts, so its input XOR is the (linear) expansion $E(R'_3) = E(L'_4)$. If we can also predict R'_2 , then (1) gives both the input and output difference of each fourth-round S-box, which is exactly what a one-round (last-round) key search needs. Predicting R'_2 is the job of the differential characteristic over rounds 1–2.

3 The differential characteristic

We use chosen plaintext pairs with difference $P' = (L'_0, 0)$, i.e. the two plaintexts differ only in the left half:

- **Round 1 (probability 1).** The right halves are equal ($R'_0 = 0$), so $F(R_0, K_1) = F(R_0^*, K_1)$ and $R'_1 = L'_0 \oplus 0 = L'_0$, with $L'_1 = R'_0 = 0$.
- **Round 2 (probability p).** The S-box input difference is $E(R'_1) = E(L'_0)$. We choose L'_0 so that $E(L'_0)$ is non-zero only in the six bits feeding a single S-box, and so that the two *outer* (neighbour-shared) bits of that chunk are zero. Then exactly one S-box is active and no neighbours are disturbed.

Searching the DDTs over all input differences of the form $0x0b_2b_3b_4b_50x0$ (outer bits zero), the best entry is in **S2**:

$$\Delta_{\text{in}} = 0x08 \longrightarrow \Delta_{\text{out}} = 0xa, \quad \text{count } 16/64, \quad p = \frac{16}{64} = \frac{1}{4}.$$

The corresponding left-half input difference is $L'_0 = 0x04000000$, and since $R'_2 = L'_1 \oplus F\text{-out}_2 = 0 \oplus P(\Delta_{\text{out}} \text{ in S2})$, right pairs have the *constant*

$$R'_2 = c = 0x40080000.$$

4 Last-round key recovery by counting

For each pair we form the predicted fourth-round F -output difference for a right pair, $R'_4 \oplus R'_2$, undo P to obtain the eight expected S-box output differences, and read the eight input differences from $E(L'_4)$. For each S-box m with non-zero input difference and every 6-bit key candidate $k \in \{0, \dots, 63\}$ we increment a counter when

$$S_m(a_m \oplus k) \oplus S_m(b_m \oplus k) = \Delta_m^{\text{out}},$$

where a_m, b_m are the actual 6-bit S-box inputs $E(R_3)_m, E(R_3^*)_m$. The correct K_4 chunk is suggested by every right pair, while wrong pairs add roughly uniform noise.

A strong structural simplification. The prediction error equals $\text{perm}P^{-1}(R'_2 \oplus c)$. Because round 2 has a *single* active S-box (S2), this error is non-zero only in S2's output nibble. Consequently the predicted output difference is *exactly correct for every pair* (right or wrong) for the seven S-boxes other than the one tied to the characteristic, and only the characteristic-linked S-box depends on the probability p . In the run this is visible: seven S-boxes are recovered with votes equal to their active-pair count, while S2 is resolved by its right pairs.

S-box	S1	S2	S3	S4	S5	S6	S7	S8
votes / active	333/333	62/342	369/369	378/378	371/371	388/388	358/358	363/363
K_4 chunk	0x22	0x16	0x39	0x21	0x26	0x3a	0x1f	0x23

Every S-box except S2 attains votes equal to its active-pair count, confirming deterministic recovery; S2 is resolved by its 62 right pairs. This recovers all 48 bits of $K_4 = 0x896E619BA7E3$.

5 Full key reconstruction

$K_4 = \text{PC2}(\text{rotl}(C_0, 6) \parallel \text{rotl}(D_0, 6))$, where $6 = 1+1+2+2$ is the total rotation after four rounds. PC-2 keeps 48 of the 56 key-schedule bits, so 8 bits are unknown. We undo the rotations, brute-force the $2^8 = 256$ missing bits against one known plaintext/ciphertext pair, and invert PC-1 to obtain the 14-hex (56-bit) key. The live run recovers

$$\boxed{\text{key} = 0\text{x}8\text{B}2\text{F}88\text{A}663\text{CB}4\text{D}}$$

which reproduces the oracle on 20 fresh random plaintexts (verification PASS).

6 Justification of the 822 oracle queries

The figure 822 is the *total number of oracle calls*, not the number of pairs. It decomposes as

$$\underbrace{1}_{\text{connectivity probe}} + \underbrace{400 \text{ pairs} \times 2}_{800 \text{ (counting attack)}} + \underbrace{1}_{\text{known pair for the 8-bit brute force}} + \underbrace{20}_{\text{fresh-plaintext verification}} = 822.$$

(The probe is a single sanity-check encryption confirming the HTTP endpoint; dropping it gives the leaner 821.)

Why 400 pairs suffice. Seven of the eight K_4 chunks are recovered deterministically (Section 4): a chunk only needs its S-box to be *active* in a handful of pairs, and since L'_4 is effectively random per pair, each S-box is active in ~ 83 – 97% of pairs (333–388 of 400 above). The binding constraint is the single probabilistic S-box (S2). The number of right pairs for it is

$$\mathbb{E}[\text{right pairs}] \approx p \times (\text{pairs where S2 is active}) \approx \frac{1}{4} \times 342 \approx 85,$$

and the run records 62 reinforcing votes for the recovered 6-bit value. The signal-to-noise argument of Biham–Shamir applies: with a 6-bit counted subkey (2^6 candidates), characteristic probability $p = 1/4$, and a single active S-box, the signal-to-noise ratio is

$$\frac{S}{N} \approx \frac{2^6 p}{\beta \gamma} \gg 1,$$

so a few tens of right pairs already separate the correct key from the noise floor; the ~ 62 obtained give a comfortable margin against all 63 wrong candidates.

Why not fewer, and why not more. Fewer pairs (e.g. 100–150) would still likely succeed but shrink the S2 margin and make the result sensitive to the particular key/data; 400 pairs buys a safety factor of several while keeping the attack robust across keys. We do not use more because the oracle enforces a **1000 queries/day per user** limit: at 800 counting queries plus the 22 probe/reconstruction/verification queries ($= 822$) the attack fits within a single day’s budget with ~ 178 queries of headroom, leaving room for connection retries and a partial re-run without tripping the rate limiter. In short, 400 pairs is the sweet spot: large enough for a wide success margin on the only probabilistic S-box, small enough to complete comfortably inside one day’s query allowance.